ANALISIS DAN PERANCANGAN SISTEM

SCOPELINE

Platform Manajemen Engagement dan Pelaporan Penetration Testing Berbasis Web

DOKUMEN PROGRAM ANALYSIS

Analisis teknis berbasis implementasi versi 1.1

Dosen Pengampu:

Agus Sulaiman, S.Kom., MT.

Disusun Oleh:

Denvi Sekartazi Iskandar (241552010020)

Pemilik Proyek: Bilal (241552010004) dan Denvi (241552010020)

PROGRAM STUDI TEKNIK INFORMATIKA

STMIK TAZKIA

Tahun Akademik 2026/2027

10 November 2026

KETERANGAN DOKUMEN

Atribut	Keterangan
Nama sistem	SCOPELINE - Platform Manajemen Engagement dan Pelaporan Penetration Testing Berbasis Web
Dokumen	Program Analysis - analisis, perancangan, dan evaluasi teknis pasca-implementasi
Baseline kebutuhan	Usulan Judul & Key Objective Proyek (2).pdf
Draft terdahulu	Analisis dan Perancangan Sistem SCOPELINE ... .pdf
Versi perangkat lunak yang dianalisis	SCOPELINE 1.1.0 (Wave 1) beserta paket konfigurasi Vercel
Status deployment saat dokumen disusun	Belum live; project Vercel sudah dibuat, database dan GitHub repository belum terhubung
Klasifikasi	Internal - Terbatas

Catatan status persetujuan baseline

Dokumen proposal diperlakukan sebagai baseline proyek yang telah disetujui sesuai keterangan pemilik proyek. Namun, salinan PDF yang tersedia masih menampilkan “0.1 / Draf untuk persetujuan” dan disclaimer draf pada halaman akhir. Karena itu, nomor/status persetujuan administratif pada salinan final perlu diselaraskan dengan dokumen persetujuan resmi. Isi kebutuhan dan ruang lingkup tetap mengikuti proposal sebagai acuan.

ABSTRAK

SCOPELINE merupakan aplikasi web internal untuk mengelola siklus operasional engagement penetration testing, mulai dari pencatatan klien, ruang lingkup dan Rules of Engagement (RoE), pencatatan temuan dan bukti, kalkulasi CVSS v3.1, peninjauan temuan, perbaikan dan retest, hingga penerbitan laporan. Dokumen Program Analysis ini menurunkan kebutuhan dari proposal proyek dan memperbarui draft analisis terdahulu berdasarkan source code SCOPELINE 1.1.0. Implementasi aktual menggunakan Python 3.12, FastAPI, SQLAlchemy, Alembic, PostgreSQL sebagai target database persisten, serta frontend HTML, CSS dan JavaScript tanpa framework yang disajikan oleh aplikasi FastAPI. Versi 1.1 menambahkan workflow review empat mata, retest per ronde, templat laporan DOCX berversi, catatan Markdown berversi, peran Technical Writer, impor CSV, dashboard dan audit log. Skema data memisahkan pengguna, engagement, anggota engagement, temuan, bukti, retest, catatan, versi catatan, templat dan audit. Keamanan ditegakkan di backend melalui Argon2id, JWT HS256, MFA TOTP, RBAC, pembatasan percobaan login, validasi Pydantic, validasi file dan audit trail. Untuk target Vercel, SQLite dan filesystem sementara tidak digunakan sebagai penyimpanan produksi; bukti disimpan sebagai BLOB di PostgreSQL. Konsekuensi platform adalah ekspor PDF dinonaktifkan karena runtime Vercel tidak menyediakan LibreOffice dan ukuran upload dibatasi 4 MB. Pada saat evaluasi, project Vercel sudah dibuat tetapi repository GitHub, koneksi PostgreSQL, secret wajib, deployment production dan domain khusus belum selesai. Oleh sebab itu, analisis membedakan fitur yang sudah ada di source code dari kriteria yang belum terbukti melalui deployment dan uji penerimaan produksi.

Kata kunci: *SCOPELINE, Program Analysis, FastAPI, RBAC, CVSS v3.1, Vercel, PostgreSQL, penetration testing.*

DAFTAR ISI

- Keterangan Dokumen dan Abstrak
- BAB I Pendahuluan
- BAB II Landasan Teori dan Metode Analisis
- BAB III Analisis Kebutuhan Sistem
- BAB IV Perancangan Proses dan Data
- BAB V Perancangan Arsitektur dan Kontrak API
- BAB VI Keamanan dan Pengujian
- BAB VII Hasil Implementasi dan Evaluasi Keterlacakan
- BAB VIII Rancangan Deployment Vercel dan Status Aktual
- BAB IX Risiko, Batasan, dan Rencana Lanjutan
- BAB X Kesimpulan
- Daftar Pustaka dan Lampiran Ringkas

BAB I PENDAHULUAN

1.1 Latar Belakang

Proposal proyek mengidentifikasi bahwa pekerjaan penguji keamanan tidak hanya terdiri atas aktivitas analisis teknis, tetapi juga pekerjaan administratif yang tersebar: pendataan ruang lingkup dan izin, pengelolaan temuan pada beberapa berkas, penilaian tingkat keparahan, serta penyusunan laporan akhir. Kondisi tersebut membuat proses berulang, sulit dilacak, dan berpotensi menghasilkan format temuan yang tidak seragam. SCOPELINE diusulkan sebagai satu platform untuk menyatukan siklus engagement dan pelaporan penetration testing [1].

Peran Program Analysis berada pada sisi teknis dari keputusan proyek. Bila proposal manajemen menjawab apa yang dibangun, mengapa proyek dibutuhkan, prioritas dan batas pelaksanaan, maka dokumen ini menjawab bagaimana kebutuhan tersebut diterjemahkan menjadi aktor, proses, model data, arsitektur, kontrak API, pengendalian keamanan, dan bukti implementasi. Dokumen ini disusun setelah source code v1.1 tersedia sehingga rancangan tidak berhenti sebagai model konseptual, tetapi membandingkan desain dengan implementasi yang benar-benar terdapat dalam repository source.

1.2 Rumusan Masalah

1. Bagaimana kebutuhan fungsional dan non-fungsional dari proposal diterjemahkan menjadi modul sistem dan kriteria verifikasi?
2. Bagaimana arsitektur aplikasi, struktur data relasional, aliran data dan kontrak API mendukung siklus engagement, RoE, temuan, retest dan pelaporan?
3. Bagaimana aturan akses per peran, kontrol empat mata, keamanan bukti, dan perhitungan CVSS ditegakkan di sisi server?
4. Bagaimana implementasi v1.1 dipetakan terhadap target proposal dan batas deployment pada Vercel?

1.3 Tujuan

- Mendokumentasikan kebutuhan sistem dan prioritas MoSCoW berdasarkan proposal proyek.
- Menghasilkan rancangan proses, arsitektur, ERD, kamus data dan katalog endpoint yang sesuai dengan implementasi.
- Menjelaskan keputusan teknis, kontrol keamanan, pengujian dan kompromi yang muncul pada v1.1.
- Mengevaluasi pencapaian target proposal dan mengidentifikasi pekerjaan tersisa sebelum sistem dinyatakan siap digunakan.

1.4 Ruang Lingkup dan Batasan

SCOPELINE adalah alat manajemen dan pelaporan. Sistem tidak melakukan pemindaian jaringan atau aplikasi, tidak mengeksploitasi target, tidak mengotomatiskan serangan, dan tidak mengandung fitur AI. Seluruh pengembangan dan pengujian harus memakai data fiktif sebagaimana dinyatakan pada proposal [1]. Multi-tenant, aplikasi seluler, dan integrasi

langsung dengan scanner berada di luar lingkup. Dokumentasi ini menganalisis source code 1.1.0 dan kondisi proyek Vercel yang dapat diverifikasi pada 10 November 2026; hasil deployment produksi belum tersedia.

1.5 Sumber Data dan Metode Analisis

Sumber	Pemanfaatan	Batas interpretasi
Proposal proyek [1]	Baseline masalah, tujuan, ruang lingkup, prioritas MoSCoW, target penerimaan, tim dan jadwal.	File salinan masih mencantumkan status draf; status telah disetujui mengikuti keterangan pemilik proyek.
Draft Program Analysis [2]	Menjaga kesinambungan struktur akademik dan mengidentifikasi bagian yang perlu diperbarui.	Draft menggambarkan v1.0; rincian yang tidak cocok dengan source v1.1 tidak dipertahankan sebagai fakta aktual.
Source SCOPELINE 1.1.0 [3]	Pemetaan modul, model data, endpoint, aturan bisnis, konfigurasi, tes dan changelog.	Keberadaan kode tidak otomatis membuktikan semua skenario lulus atau telah live di production.
Vercel project/API state [4]	Status project, alias, env vars, integrasi, proteksi dan histori deployment.	Status diperiksa pada 10 November 2026; belum ada deployment production.

Metode kerja: (1) ekstraksi kebutuhan dari proposal; (2) pengelompokan dan pemberian ID FR/NFR; (3) inspeksi source code dan migrasi basis data; (4) rekonstruksi workflow, ERD, DFD dan API; (5) pemetaan kontrol keamanan; (6) pencatatan status build, uji dan deployment yang dapat dibuktikan. Temuan yang hanya berupa rencana ditandai sebagai rencana, sedangkan klaim keberhasilan uji produksi tidak dibuat tanpa log atau hasil verifikasi.

BAB II LANDASAN TEORI DAN METODE ANALISIS

2.1 Rekayasa Kebutuhan

Kebutuhan fungsional menjelaskan layanan yang diberikan sistem, sedangkan kebutuhan non-fungsional menetapkan atribut mutu dan batasan seperti keamanan, kinerja, keandalan dan kemudahan pemeliharaan. Setiap kebutuhan perlu memiliki identitas, prioritas, asal-usul dan kriteria uji agar dapat dilacak dari proposal sampai implementasi [2].

2.2 Prioritas MoSCoW

MoSCoW digunakan dalam proposal untuk membatasi lingkup pada Must, Should, Could dan Won’t. Pada dokumen ini, kategori proposal dipertahankan. Fitur tambahan yang muncul pada versi 1.1 dipisahkan sebagai perluasan implementasi, bukan dipindahkan diam-diam ke komitmen awal.

2.3 Arsitektur Klien-Server dan Pemisahan Lapisan

Pola klien-server memisahkan antarmuka browser dari layanan backend. Pada SCOPELINE, JavaScript mengirim permintaan JSON atau multipart melalui HTTPS ke FastAPI. Middleware dan dependency menangani header keamanan, autentikasi serta otorisasi; router menangani aturan bisnis; SQLAlchemy menjadi lapisan akses data. Pemisahan ini memudahkan perubahan frontend dan database tanpa memindahkan aturan bisnis ke browser.

2.4 Basis Data Relasional dan Integritas

Model relasional menghubungkan entitas melalui primary key dan foreign key. V1.1 memecah relasi pengguna-engagement menjadi tabel penghubung, bukti menjadi entitas tersendiri, dan retest menjadi entitas berulang per temuan. Bukti binary dan template DOCX disimpan pada kolom BLOB agar storage tidak bergantung pada disk instance. Tabel audit mencatat identitas pelaku sebagai nilai user_id dan username; pada skema saat ini user_id audit belum didefinisikan sebagai foreign key.

2.5 REST API

API disusun berbasis resource dan metode HTTP. GET digunakan untuk membaca, POST untuk membuat atau menjalankan transisi, PUT/PATCH untuk memperbarui dan DELETE untuk menghapus. Endpoint memakai prefiks /api dan mengirim token pada header Authorization: Bearer. Kontrak API harus konsisten untuk request, response, status sukses dan galat; validasi tidak boleh hanya bergantung pada frontend.

2.6 RBAC dan Separation of Duties

Role-Based Access Control memberikan izin berdasarkan peran, bukan mengatur izin satu per satu untuk setiap pengguna. SCOPELINE mengimplementasikan lima peran. Kontrol empat mata mencegah pembuat temuan menyetujui temuan buatannya sendiri, sedangkan penguji hanya dapat mengakses engagement tempat dirinya ditugaskan. Peran Technical Writer dibatasi pada teks temuan dan laporan, tanpa akses ke bukti mentah.

2.7 Keamanan Aplikasi dan CVSS

Daftar periksa OWASP ASVS Level 1 dipakai sebagai kerangka pemeriksaan mandiri, bukan sertifikasi otomatis. CVSS v3.1 digunakan sebagai metode penilaian severity dari vector metrik dasar. Implementasi menghitung skor di backend sehingga klien tidak dapat mengirim skor akhir secara bebas. Nilai skor yang tercatat harus tetap dapat dilacak ke vector yang menjadi input [2], [3].

BAB III ANALISIS KEBUTUHAN SISTEM

3.1 Aktor dan Hak Akses

Empat peran pada proposal (Admin, Lead, Penguji, Peninjau) diperluas pada v1.1 dengan Technical Writer. Perluasan ini berasal dari kebutuhan menyusun laporan secara terpisah dari pengujian teknis dan dicatat sebagai perubahan desain pada versi implementasi.

Aktor	Tanggung jawab utama	Batasan akses utama
Admin	Pengelolaan sistem dan pengguna; memiliki kewenangan Lead.	Mengelola pengguna; operasi sistem; tetap mengikuti kontrol empat mata ketika menyetujui temuan sendiri.
Lead	Mengelola engagement, anggota, RoE, template, audit dan review.	Tidak boleh menyetujui temuan yang dibuat sendiri.
Penguji / Tester	Mencatat temuan, bukti, status perbaikan, ronde retest dan catatan.	Hanya engagement yang ditugaskan; perubahan teknis hanya ketika engagement aktif dan RoE disetujui.
Peninjau / Reviewer	Membaca temuan, memberi keputusan review dan mengakses laporan/bukti sesuai hak.	Tidak membuat atau mengubah data teknis; approval memerlukan status menunggu review.
Technical Writer	Menyunting teks temuan dan mengelola templat laporan.	Tidak dapat melihat atau mengunduh bukti mentah; tidak dapat mengubah CVSS, bukti atau retest.

3.2 Kebutuhan Fungsional

ID	Modul	Deskripsi kebutuhan	Prioritas	Kriteria verifikasi
FR-01	Autentikasi	Login dengan username/password; token akses; ganti password; MFA TOTP.	Must	401 kredensial salah; token kedaluwarsa/tidak valid ditolak; MFA diverifikasi.
FR-02	Manajemen pengguna	Admin membuat pengguna, mengubah role dan mengaktifkan/menonaktifkan akun.	Must	Akses non-admin ditolak; password memenuhi kebijakan minimal.
FR-03	Manajemen engagement	Membuat dan memperbarui klien, nama, scope, tanggal, RoE dan status.	Must	Data tersimpan; tanggal divalidasi; akses objek mengikuti assignment.
FR-04	Persetujuan RoE	Admin/Lead menyetujui RoE secara eksplisit.	Must	Status aktif sebelum RoE disetujui ditolak dengan HTTP 409.
FR-05	Assignment tim	Admin/Lead menetapkan anggota engagement.	Must	Penguji hanya dapat membaca/mengubah engagement yang ditugaskan.

ID	Modul	Deskripsi kebutuhan	Prioritas	Kriteria verifikasi
FR-06	Pencatatan temuan	Menambah/ mengubah judul, deskripsi, dampak, rekomendasi, vector, tenggat dan status.	Must	Temuan hanya dibuat saat engagement aktif dan RoE telah disetujui.
FR-07	Bukti temuan	Unggah, unduh dan hapus bukti sesuai hak akses; bukti terkait temuan atau retest.	Must	Ekstensi, ukuran dan signature berkas diperiksa; nama storage acak.
FR-08	Kalkulator CVSS	Menghitung CVSS v3.1 dari vector pada backend.	Must	Vector invalid ditolak; nilai acuan FIRST diuji.
FR-09	Ekspor laporan	Membuat laporan pretest/retest DOCX; mendukung PDF bila runtime memiliki LibreOffice.	Must	DOCX berisi temuan yang dipilih; laporan final hanya memuat temuan yang disetujui.
FR-10	Retest per temuan	Mencatat ronde retest, tanggal, penguji, hasil, catatan dan bukti.	Should	Passed menghasilkan status lulus retest; failed/partial membuka kembali.
FR-11	Review temuan	Workflow draft → in_review → approved/changes_requested.	Tambahan v1.1	Pembuat tidak dapat menyetujui temuannya sendiri; perubahan isi mengembalikan status ke draft.
FR-12	Dashboard dan audit	Ringkasan engagement/temuan serta pencatatan tindakan penting.	Should	Dashboard terfilter sesuai akses; audit event tercatat.
FR-13	Impor CSV	Impor hingga batas yang ditetapkan dengan validasi per baris.	Could	CSV UTF-8 valid; baris invalid dilaporkan dan tidak diproses.
FR-14	Templat temuan	Mengelola pustaka templat judul/deskripsi/dampak/rekomendasi/vector.	Tambahan v1.1	Role yang berwenang dapat membuat dan menghapus templat.
FR-15	Templat laporan berversi	Unggah, validasi, aktifkan dan arsipkan template pretest/retest.	Tambahan v1.1	Template validasi placeholder; versi aktif dapat diidentifikasi.
FR-16	Catatan Markdown	Templat catatan, catatan tim/pribadi, riwayat versi, ekspor Markdown.	Tambahan v1.1	Akses catatan pribadi dibatasi pemilik/Lead/Admin; HTML mentah tidak dieksekusi.
FR-17	Notifikasi email remediasi	Mengirim pengingat tenggat remediasi.	Could	Belum diimplementasikan pada source v1.1.

3.3 Kebutuhan Non-Fungsional

ID	Kebutuhan	Kriteria verifikasi
NFR-01 Keamanan	RBAC di setiap endpoint dan pengecekan assignment untuk akses objek.	401 tanpa token; 403 untuk role tidak sesuai; akses objek yang tidak ditugaskan ditolak.
NFR-02 Autentikasi	Hash Argon2id, JWT HS256, token revocation, lockout, MFA TOTP.	Password tidak disimpan plaintext; perubahan password/role menaikkan token_version.
NFR-03 Validasi	Validasi Pydantic, CVSS vector, CSV dan file upload.	Input tidak valid ditolak dengan status 4xx; jenis/ukuran/isi file diperiksa.
NFR-04 Auditabilitas	Tindakan penting disimpan dalam audit_log.	Login, perubahan RoE, temuan, review, upload dan ekspor meninggalkan jejak.
NFR-05 Persistensi	Production membutuhkan PostgreSQL persisten; bukti/template disimpan di DB.	Tidak ada data penting yang hanya berada pada /tmp atau filesystem Function.
NFR-06 Kemudahan deployment	Satu project Vercel dengan FastAPI; env vars disuntik dari project settings.	Aplikasi tidak start bila PostgreSQL/secret wajib belum diatur.
NFR-07 Batas file pada Vercel	Upload aplikasi dibatasi 4 MB untuk menjaga body request di bawah 4.5 MB.	Upload >4 MB ditolak.
NFR-08 Pelaporan	DOCX berjalan pada runtime; PDF perlu LibreOffice.	PDF dimatikan pada Vercel; DOCX menjadi format ekspor aktif.
NFR-09 Keamanan header	CSP, X-Content-Type-Options, X-Frame-Options, Referrer-Policy, no-store untuk API.	Header diperiksa dalam uji HTTP.

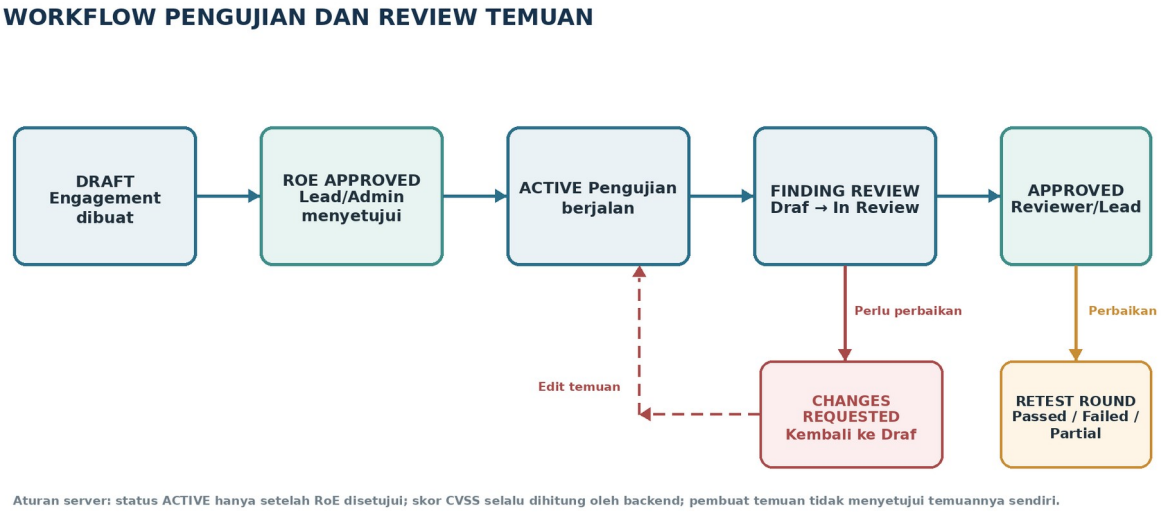
3.4 Kebutuhan yang Tidak Masuk Lingkup

- Pemindaian kerentanan dan integrasi scanner langsung.
- Eksploitasi, otomasi serangan, dan eksekusi payload terhadap target.
- Aplikasi seluler dan multi-tenant.
- Penggunaan data klien nyata selama pengembangan/pengujian.
- Fitur berbasis AI dan notifikasi email tenggat pada rilis ini.

BAB IV PERANCANGAN PROSES DAN DATA

4.1 Alur Bisnis Engagement dan RoE

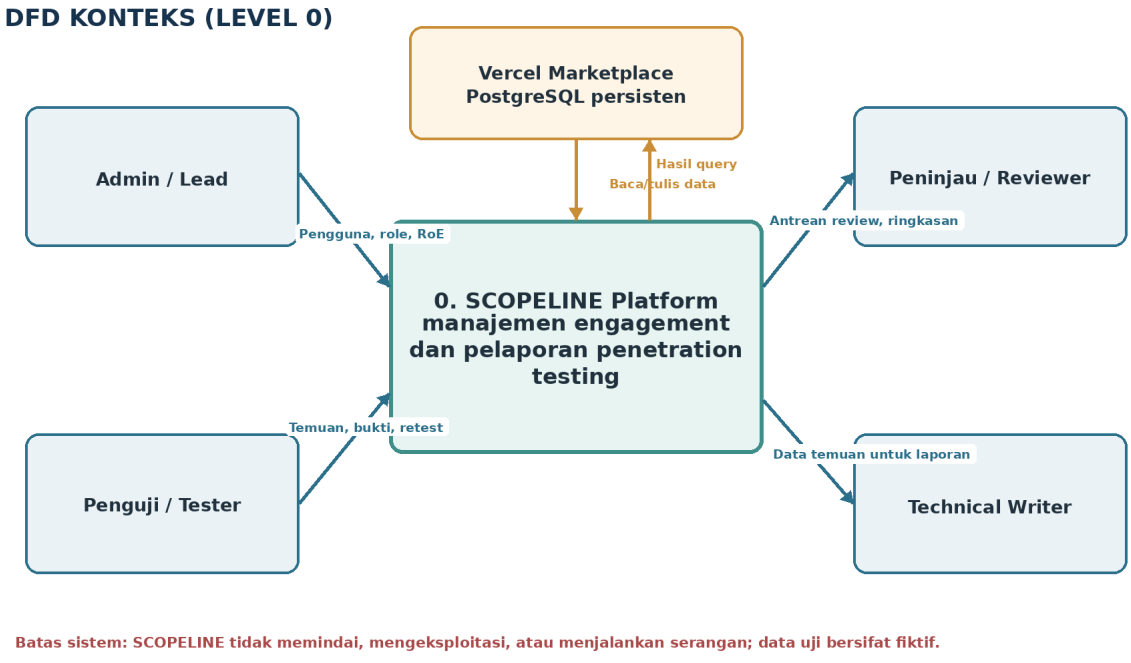
Engagement dimulai pada status draft. Admin atau Lead mengisi klien, ruang lingkup, periode dan teks RoE, kemudian menetapkan anggota. Persetujuan RoE dicatat beserta pelaku dan waktu. Backend menolak transisi ke active sebelum RoE disetujui. Perubahan pada scope atau RoE menghapus status persetujuan agar tim tidak melanjutkan pekerjaan berdasarkan izin yang sudah berubah.



Gambar 1. Alur engagement, review temuan dan retest pada SCOPELINE 1.1.

4.2 Data Flow Diagram - Context / Level 0

Pada level konteks, SCOPELINE berinteraksi dengan lima jenis aktor. Pengguna mengirim data autentikasi, engagement, temuan, bukti, review dan catatan. SCOPELINE mengembalikan status, ringkasan, histori dan laporan. Database PostgreSQL persisten menjadi data store utama untuk akun, engagement, temuan, bukti, template, catatan dan audit.

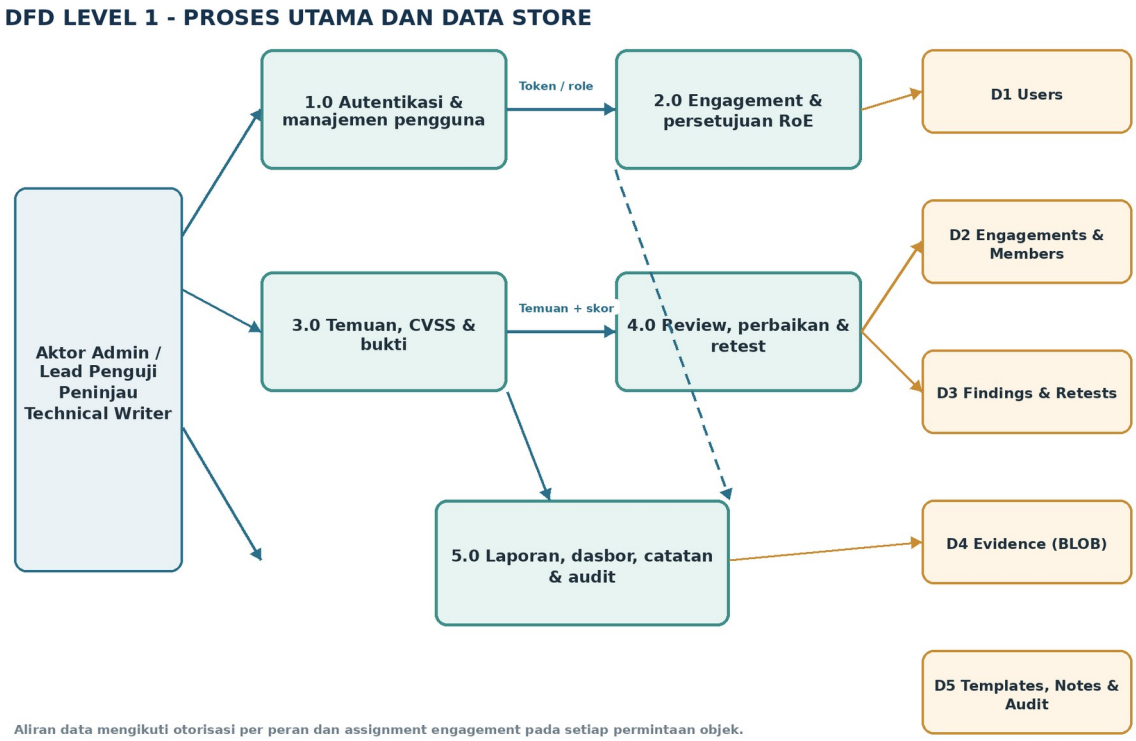


Gambar 2. DFD konteks SCOPELINE (Level 0).

4.3 Data Flow Diagram - Level 1

Proses internal dipisah menjadi autentikasi/pengguna, manajemen engagement/RoE, temuan/CVSS/bukti, review/perbaikan/retest, serta laporan/dashboard/catatan/audit. Data store

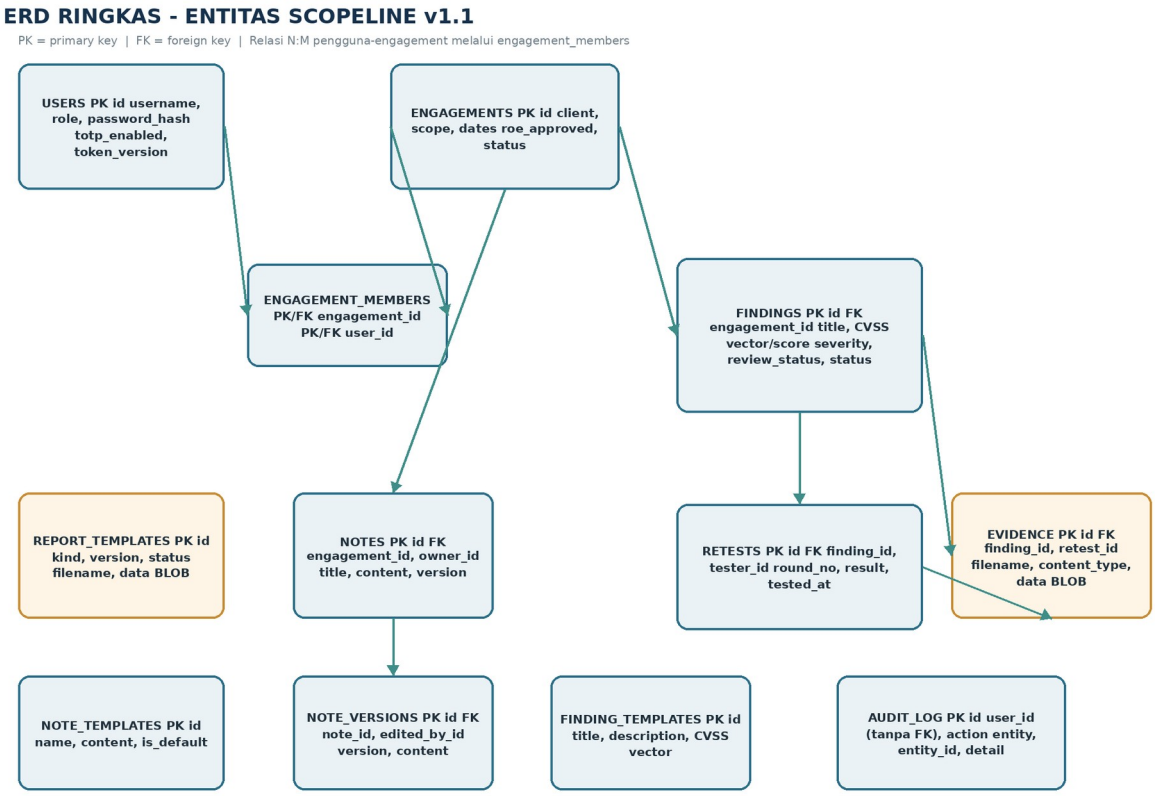
logis menunjukkan pengelompokan data walaupun secara fisik tabel berada pada satu database. Alur akses antar proses dibatasi oleh dependency autentikasi, RBAC dan assignment engagement.



Gambar 3. DFD Level 1 - proses utama dan kelompok data store.

4.4 Perancangan ERD

Skema v1.1 menggunakan SQLAlchemy ORM dan migrasi Alembic. Relasi pengguna-engagement menggunakan tabel penghubung engagement_members; satu engagement memiliki banyak temuan; satu temuan dapat memiliki banyak bukti dan banyak ronde retest; satu ronde retest juga dapat memiliki bukti. Notes dan note_versions memisahkan isi catatan saat ini dari histori versi. ReportTemplate menyimpan bytes DOCX; Evidence memiliki kolom data BLOB untuk penyimpanan bukti di database.



Gambar 4. ERD ringkas entitas utama SCOPELINE 1.1. Diagram menonjolkan entitas dan relasi utama, bukan seluruh foreign key turunan.

4.5 Kamus Data

Tabel	Tujuan	Kolom utama
users	Akun dan role	id PK; username UNIQUE; full_name; password_hash; role; is_active; failed_attempts; locked_until; totp_secret; totp_enabled; token_version; created_at.
engagements	Identitas engagement dan RoE	id PK; name; client; scope; start_date; end_date; roe_text; roe_approved; roe_approved_by_id FK; roe_approved_at; status; created_by_id FK; created_at.
engagement_members	Relasi N:M user-engagement	engagement_id PK/FK; user_id PK/FK.
findings	Temuan teknis	id PK; engagement_id FK; number; title; description; impact; recommendation; cvss_vector; cvss_score; severity; status; review_status; review_note; due_date; created_by_id.
evidence	Bukti temuan/retest	id PK; finding_id FK; retest_id FK nullable; filename; stored_name; content_type; size; data BLOB nullable; uploaded_by_id FK; uploaded_at.
retests	Ronde verifikasi ulang	id PK; finding_id FK; round_no; result; tested_at; notes; tester_id FK; created_at; unique(finding_id, round_no).
finding_templates	Pustaka template temuan	id PK; title; description; impact; recommendation; cvss_vector.

Tabel	Tujuan	Kolom utama
audit_log	Jejak aktivitas	id PK; created_at; user_id; username; action; entity; entity_id; detail. user_id belum menjadi FK pada skema saat ini.
note_templates	Template catatan Markdown	id PK; name UNIQUE; content; is_default; updated_by_id FK; timestamps.
notes	Catatan tim/pribadi	id PK; engagement_id FK; owner_id FK nullable; title; content; version; timestamps; updated_by_id FK.
note_versions	Riwayat perubahan catatan	id PK; note_id FK; version; content; edited_by_id FK; created_at; unique(note_id, version).
report_templates	Template laporan DOCX	id PK; kind; version; status; filename; notes; size; data BLOB; created_by_id; created_at; activated_at; unique(kind, version).

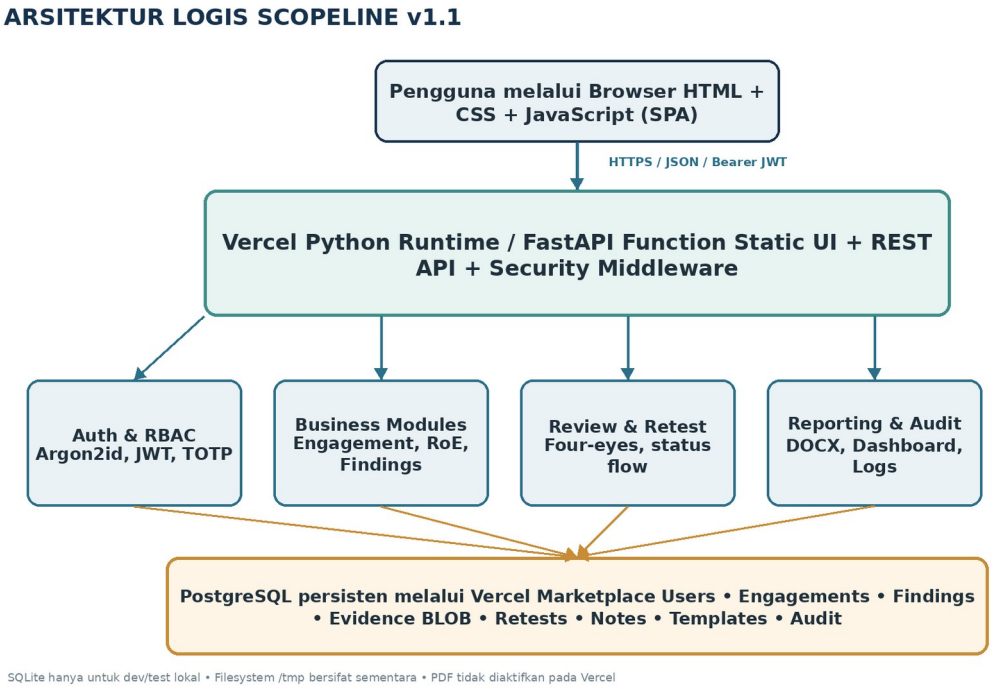
4.6 Aturan Integritas dan Status

- Engagement: draft → active → completed; transisi menjadi active mensyaratkan RoE disetujui.
- Finding: open → fixed → retest_passed; status retest_passed dihasilkan oleh ronde retest yang berhasil.
- Review temuan: draft → in_review → approved atau changes_requested; perubahan isi penting mereset status review ke draft.
- Final report hanya menyertakan temuan approved; opsi menyertakan temuan lain harus menandai laporan sebagai DRAF.
- Satu finding memiliki nomor unik per engagement; satu finding memiliki nomor ronde retest unik.
- File bukti memiliki batas jumlah per temuan, whitelist ekstensi dan pemeriksaan signature/magic bytes.

BAB V PERANCANGAN ARSITEKTUR DAN KONTRAK API

5.1 Arsitektur Logis

Frontend SCOPELINE merupakan SPA HTML/CSS/JavaScript tanpa proses bundling. Browser menampilkan halaman dari backend FastAPI dan mengirim request ke endpoint /api. FastAPI menjalankan middleware keamanan, router domain, dependency autentikasi/RBAC dan layanan pelaporan. SQLAlchemy berkomunikasi dengan PostgreSQL; Alembic memutakhirkan skema. Vercel menjadi platform deployment dan runtime Functions. Untuk deployment Vercel, frontend dan backend berada dalam satu project dan satu aplikasi FastAPI; tidak ada project frontend terpisah.



Gambar 5. Arsitektur logis target Vercel untuk SCOPELINE 1.1.

5.2 Pemilihan Teknologi dan Dampak

Komponen	Pilihan	Alasan	Dampak / kompromi
Backend	Python 3.12 + FastAPI	Validasi berbasis Pydantic, REST API, dukungan Python runtime Vercel.	Satu FastAPI app melayani static frontend dan API.
Frontend	HTML, CSS, JavaScript murni	Tidak membutuhkan build step; ringan untuk MVP.	Skala UI lebih besar meningkatkan kebutuhan modularisasi frontend.
ORM / migrasi	SQLAlchemy 2 + Alembic	Relasi SQL dan migrasi skema terkontrol.	Startup Vercel menjalankan migrasi; advisory lock mengurangi race saat cold start.
Database	PostgreSQL persisten pada Vercel Marketplace	Foreign key, transaksi dan BLOB bukti/template.	Belum diprovisikan pada project; SQLite hanya dev/test.
Autentikasi	Argon2id, JWT HS256, TOTP	Hash password, token terverifikasi, MFA.	MFA opsional per akun; rahasia dan DB tetap perlu perlindungan.
Reporting	python-docx; LibreOffice untuk PDF	DOCX dapat dibuat di Python runtime.	PDF dinonaktifkan di Vercel karena LibreOffice tidak tersedia.
Platform	Vercel Python Runtime / Functions	Satu platform untuk deployment project dan runtime.	Tidak menyediakan disk persisten; ukuran request body Function maksimum 4.5 MB.
Quality	pytest, coverage, Ruff, Bandit, pip-audit, E2E Node	Automated test dan security/dependency checks.	Hasil CI/coverage terakhir harus diperiksa dari workflow aktual.

5.3 Kontrak API - Ringkasan Endpoint

Kelompok	Endpoint representatif	Akses	Catatan kontrak
Auth	POST /api/auth/login; GET /api/auth/me; POST /api/auth/change-password; POST /api/auth/mfa/setup|enable|disable	Publik untuk login; endpoint lain memerlukan token.	Bearer JWT; OTP bila MFA aktif.
Users	GET/POST /api/users; PATCH /api/users/{uid}	Admin.	Pengelolaan akun dan role.
Engagements	GET/POST /api/engagements; GET/PATCH /api/engagements/{eid}; PUT /api/engagements/{eid}/members; POST /api/engagements/{eid}/roe/approve; POST /api/engagements/{eid}/status	Admin/Lead; penguji/reviewer/writer dibatasi assignment.	RoE approval dan status transition divalidasi di server.
Findings	POST /api/cvss/calc; GET/POST /api/engagements/{eid}/findings; PATCH/DELETE /api/findings/{fid}; POST /api/findings/{fid}/review|status| retests	Sesuai role dan status engagement.	Skor dihitung di backend; review workflow ditegakkan server.
Evidence	POST /api/findings/{fid}/evidence; POST /api/retests/{rid}/evidence; GET /api/evidence/{evid}/download; DELETE /api/evidence/{evid}	Penulis teknis yang berwenang; Technical Writer tidak boleh mengakses bukti mentah.	Upload terbatas tipe/ukuran; bukti disimpan sebagai BLOB jika EVIDENCE_IN_DB=1.
Templates	GET/POST /api/report-templates; GET /api/report-templates/{tid}/validate|download; POST /api/report-templates/{tid}/activate; /api/note-templates/*	Admin/Lead/Technical Writer sesuai jenis aksi.	Template report berversi; note template Markdown.
Notes	GET/POST /api/engagements/{eid}/notes; GET/PUT/DELETE /api/notes/{nid}; GET /api/notes/{nid}/versions; GET /api/notes/{nid}/export	Akses catatan tim atau pribadi sesuai role/pemilik.	Riwayat versi, deteksi konflik, ekspor Markdown.
Reports & dashboard	GET /api/engagements/{eid}/report; GET /api/engagements/{eid}/comparison; GET /api/dashboard; GET /api/audit	Sesuai akses engagement dan role.	DOCX tersedia di Vercel; PDF dimatikan; audit hanya untuk role staff.

Galat utama yang dipakai backend mencakup 401 (belum terautentikasi/kredensial salah), 403 (role atau izin tidak cukup), 404 (objek tidak ditemukan atau tidak dapat diakses), 409 (transisi bisnis tidak valid, misalnya RoE belum disetujui), 413 (batas ukuran), 415 (tipe/isi file tidak diizinkan), 422 (validasi input) dan 503 (fitur PDF dinonaktifkan pada runtime).

BAB VI KEAMANAN DAN PENGUJIAN

6.1 Kontrol Keamanan yang Diterapkan pada Source

Area	Kontrol pada source	Catatan / gap
Autentikasi	Argon2id untuk password; JWT HS256; token version untuk pencabutan; MFA TOTP tersedia.	Terverifikasi pada source; uji runtime perlu dijalankan ulang.
Brute-force	5 kegagalan login memicu lock akun default 15 menit; rate limit IP di memori proses.	Rate limit IP tidak dibagi antar instance serverless.
RBAC & object access	Dependency role dan pemeriksaan keanggotaan engagement.	Akses objek harus diuji ulang pada deployment multi-instance.
Input / SQL	Pydantic schemas dan SQLAlchemy ORM.	Tetap perlu uji negatif dan review query khusus.
Upload	Whitelist png/jpg/jpeg/gif/pdf/txt/log, magic bytes, batas bytes, UUID storage name.	Vercel membatasi menjadi 4 MB; request body Function limit 4.5 MB.
XSS / Browser	Frontend memakai textContent/node building untuk teks dinamis; CSP tanpa inline script/style.	Token berada di sessionStorage; risiko pencurian token akibat XSS tetap perlu diantisipasi.
Audit	Audit log untuk login, RoE, temuan, review, bukti, template dan ekspor.	Kolom audit user_id pada model belum memiliki FK.
Data at-rest	BLOB dalam PostgreSQL untuk evidence/templates pada mode EVIDENCE_IN_DB.	Enkripsi at-rest/backup/retention mengikuti provider database; harus diverifikasi di Marketplace.
Transport	HTTPS disediakan oleh Vercel pada domain yang terpasang.	Custom domain project belum terpasang; uji TLS perlu dilakukan setelah domain tersedia.

6.2 Pemeriksaan Mandiri ASVS Level 1

Repository menyertakan `docs/ASVS-L1-checklist.md` yang menandai banyak kontrol sebagai telah diimplementasikan dan diuji otomatis. Penandaan tersebut adalah dokumentasi internal proyek; dokumen ini tidak menyamakan checklist dengan verifikasi independen atau hasil audit eksternal. Area yang perlu diperiksa ulang meliputi rate limiting lintas instance, enkripsi secret TOTP, enkripsi dan backup database, retensi bukti, sessionStorage, dan deployment TLS/domain.

6.3 Strategi Pengujian dan Bukti yang Tersedia

- Unit/API tests: test_cvss.py, test_api.py dan test_wave1.py; source memuat 31 fungsi test_ dan beberapa kasus parameterisasi.
- End-to-end UI: e2e/ui.test.js; source mendefinisikan 13 langkah lintas role dan alur utama.
- CI: GitHub Actions menjalankan Ruff, Bandit, pip-audit, pytest coverage dengan target 70%, uji database PostgreSQL, E2E UI dan build Docker.
- Validasi CVSS: pengujian terhadap vector/score rujukan dan penolakan vector tidak valid.

- Uji negatif: autentikasi, RBAC, assignment, RoE gate, validasi upload, status review empat mata, anti-XSS dan hak Technical Writer.

Keterbatasan verifikasi pada sesi ini

Pengujian otomatis tidak dapat dieksekusi ulang di lingkungan pemeriksaan karena dependency `pyotp` belum tersedia dan akses jaringan untuk memasang dependency tidak berhasil. Karena itu, klaim test lulus yang tercantum pada README/CHANGELOG diperlakukan sebagai catatan dari source project, bukan hasil run baru yang diverifikasi pada 10 November 2026.

BAB VII HASIL IMPLEMENTASI DAN EVALUASI KETERLACAKAN

7.1 Pemetaan Proposal ke Implementasi

Item proposal	Prioritas	Hasil implementasi v1.1	Penilaian
Autentikasi, pengguna dan role	Must	Ada; RBAC 5 role, Argon2id, JWT HS256, MFA TOTP.	Kesesuaian kode ada; uji produksi belum tersedia.
Engagement, scope, periode dan RoE	Must	Ada; status dan persetujuan RoE; assignment anggota.	Gating RoE dikerjakan di backend.
Temuan dan bukti	Must	Ada; metadata temuan, upload/download/delete evidence, retest evidence.	Vercel: harus EVIDENCE_IN_DB=1 dan PostgreSQL; env telah disiapkan, DB belum terhubung.
CVSS v3.1	Must	Ada; backend menghitung score dan severity dari vector.	Nilai acuan ada pada tests; belum dijalankan ulang di sesi ini.
Ekspor laporan DOCX/PDF	Must	DOCX ada; PDF memerlukan LibreOffice.	PDF disabled di Vercel (ENABLE_PDF=0); kriteria PDF tidak terpenuhi pada runtime Vercel.
Pelacakan perbaikan/retest	Should	Ada; status dan ronde retest per temuan.	Workflow ada di source; deployment belum diuji.
Dashboard dan audit log	Should	Ada.	Nilai aktual bergantung pada data di database.
Impor CSV	Could	Ada.	Batas ukuran 1 MB dan maksimum 500 baris pada code.
Notifikasi email	Could	Belum ada.	Tenggat dapat tersimpan dan ditampilkan sebagai overdue; tidak ada pengiriman email.
Scanning/exploitation/AI	Won’t	Tidak ada.	Tetap dikecualikan secara sengaja.

7.2 Penambahan Fitur pada v1.1

- Migrasi database Alembic dengan baseline dan migrasi Wave 1.
- Templat laporan DOCX terpisah untuk pretest dan retest, berversi, tervalidasi dan dapat diaktifkan/diarsipkan.
- Catatan Markdown tim/pribadi dengan template, histori versi, deteksi konflik dan ekspor.
- Workflow review temuan dengan pemisahan pembuat dan peninjau (four-eyes).
- Ronde retest berulang beserta evidence retest dan perbandingan pretest/retest.
- Peran Technical Writer dengan akses teks terbatas dan tanpa bukti mentah.

7.3 Kriteria Keberhasilan yang Belum Terbukti

Target proposal	Kondisi saat ini	Bukti yang masih diperlukan
Laporan dibuat <10 menit	Belum diukur.	Uji waktu pada skenario dan data uji standar; laporkan median dan maksimum.
Cakupan pengujian otomatis ≥70%	CI mendefinisikan ambang 70%; hasil coverage terakhir belum diverifikasi pada sesi ini.	Workflow run sukses dan artefak coverage untuk commit rilis.
Tidak ada temuan kritis/tinggi terbuka pada ASVS L1	Checklist internal ada; audit manual/independen belum dibuktikan.	Checklist terisi evidence, review pembimbing, daftar gap dan retest.
Instalasi satu perintah Docker Compose	Compose disediakan untuk lokal; hasil clean-install belum diulang pada sesi ini.	Build/run dari environment bersih dan dokumentasi konfigurasi.
Deployment staging aktif	Project Vercel dibuat, tetapi deployment belum ada.	Database, secrets, GitHub repo, deployment READY, health check dan demo end-to-end.

BAB VIII RANCANGAN DEPLOYMENT VERCEL DAN STATUS AKTUAL

8.1 Alasan Penyesuaian Platform

Implementasi awal menyediakan Docker Compose, PostgreSQL/SQLite, dan filesystem volume lokal. Permintaan implementasi saat ini menetapkan Vercel sebagai platform hosting untuk frontend, backend dan pengelolaan database. FastAPI dapat berjalan pada Python runtime Vercel; aplikasi diekspor melalui entrypoint yang dikenali atau `tool.vercel.entrypoint` pada pyproject.toml [4].

Vercel tidak lagi menyediakan produk Vercel Postgres native untuk project baru. PostgreSQL untuk project Vercel baru tersedia melalui integrasi penyimpanan/database di Vercel Marketplace, yang dapat menyediakan provider seperti Prisma Postgres, Neon, Supabase atau AWS Aurora [4]. Dengan demikian, frontend dan runtime API berada pada Vercel, sementara database PostgreSQL perlu diprovisikan melalui Marketplace yang

terhubung dari dashboard Vercel. Tidak tepat menyebut database sebagai server PostgreSQL native yang dioperasikan langsung oleh Vercel.

8.2 Penyesuaian Source untuk Runtime Vercel

- Root `requirements.txt` disediakan agar dependency Python dapat dipasang pada build Vercel.
- `.python-version` menetapkan Python 3.12; `pyproject.toml` mendefinisikan dependency proyek dan entrypoint `backend.app.main:app`.
- `vercel.json` memakai schema resmi; framework project pada Vercel diset ke FastAPI.
- Konfigurasi menolak start jika DATABASE_URL tidak ada atau menunjuk SQLite, SECRET_KEY kurang dari 32 karakter, ADMIN_PASSWORD kurang dari 12 karakter, evidence tidak diatur ke database, atau ENABLE_PDF aktif.
- Bukti dan template disimpan pada PostgreSQL melalui BLOB; filesystem /tmp hanya untuk kerja sementara.
- Migrasi Alembic berjalan ketika FastAPI lifespan dimulai dan menggunakan PostgreSQL advisory lock.
- Upload dibatasi menjadi 4 MB, di bawah payload limit Vercel Function sebesar 4.5 MB [4].
- PDF dinonaktifkan karena konversi PDF memerlukan LibreOffice yang tidak dibundel dalam runtime; DOCX tetap tersedia.

8.3 Status Project Vercel per 10 November 2026

Item	Status yang diverifikasi
Project	`scopeline` dibuat; framework FastAPI; project ID `prj_2klzYjPraT5VYpIpBcZmS4XR49B7`.
Region / team	Region Function belum ditetapkan atau terverifikasi pada project settings; team Vercel `zerocool979's projects` pada paket Hobby.
Alias otomatis	`scopeline-six.vercel.app` terpasang dan terverifikasi, tetapi `latestDeployment=null`.
Deployment history	Belum ada deployment untuk project ini (`live=false`).
SSO protection	Aktif pada deployment URL non-custom-domain; alias fallback tidak otomatis publik.
Environment variables sudah dipasang	DATA_DIR=/tmp/scopeline; EVIDENCE_IN_DB=1; ENABLE_PDF=0; MAX_UPLOAD_MB=4; ENABLE_DOCS=0.
Environment variables wajib yang belum ada	DATABASE_URL, SECRET_KEY dan ADMIN_PASSWORD.
Koneksi GitHub	Belum ada repository/remote yang terhubung ke project.

8.4 Kendala Domain dan Repository

Domain yang diminta pada instruksi terakhir adalah `scopelline.vercel.app` (dengan dua huruf “l” berurutan pada “ll”). Pemeriksaan ketersediaan mengembalikan `available=false`. Nama yang sebelumnya diminta, `scopeline.vercel.app`, juga tidak dapat ditambahkan: Vercel

menolak permintaan dengan kode `owned-on-other-team`. Alias `scopeline-six.vercel.app` adalah fallback yang telah dibuat otomatis oleh Vercel, tetapi belum memiliki deployment.

Repository target GitHub `zerocool979/scopeline` belum ditemukan dalam daftar repository yang dapat diakses. Konektor GitHub yang tersedia pada sesi pemeriksaan tidak menyediakan operasi create repository; karena itu repository belum dapat dibuat atau di-push secara langsung dari sesi ini. Source tree siap repository disediakan terpisah sebagai ZIP. Project Vercel sudah ada tetapi belum dapat dihubungkan otomatis ke GitHub sebelum repository tersedia.

Status akhir deployment saat laporan dibuat

Belum live. Project Vercel dan konfigurasi dasar sudah dibuat, tetapi database, secret wajib, repository GitHub, deployment production, domain publik dan uji kesehatan masih belum tersedia. Tidak ada klaim bahwa `scopeline-six.vercel.app` atau domain lain sudah menjalankan SCOPELINE.

BAB IX RISIKO, BATASAN, DAN RENCANA LANJUTAN

9.1 Risiko Teknis Aktual

Risiko	Level	Dampak	Mitigasi
Database tidak tersedia	Tinggi	Aplikasi gagal start atau tidak dapat mempertahankan data.	Provision PostgreSQL dari Vercel Marketplace, pasang DATABASE_URL, verifikasi koneksi dan migrasi.
Secret bootstrap belum tersedia	Tinggi	FastAPI menolak start atau kredensial awal tidak aman.	Buat SECRET_KEY acak ≥32 karakter dan ADMIN_PASSWORD ≥12 karakter melalui Vercel env settings.
Alias domain dikuasai project lain	Sedang	URL pilihan tidak dapat dipakai sebagai alias.	Pakai alias tersedia atau domain alternatif yang dapat diverifikasi.
GitHub repo belum ada	Tinggi	Tidak ada source-of-truth dan auto-deploy dari Git.	Buat repository private/public sesuai keputusan proyek, push source, hubungkan Vercel ke branch production.
SSO protection aktif	Sedang	Alias Vercel mungkin hanya bisa dibuka anggota team.	Tentukan mode demo; pertahankan autentikasi aplikasi dan atur proteksi Vercel secara sadar.
Rate limit in-memory	Sedang	Batas IP tidak konsisten antar instance Function.	Pindahkan counter ke database/Redis atau gunakan mekanisme edge yang persisten.
PDF export tidak tersedia di Vercel	Sedang	Format PDF dalam proposal tidak seluruhnya terpenuhi pada platform.	Gunakan DOCX untuk Vercel atau rencanakan layanan konversi yang disetujui tanpa menyatakan PDF tersedia.

Risiko	Level	Dampak	Mitigasi
Upload size limit	Sedang	Berkas besar tidak dapat diunggah.	Gunakan upload langsung ke object storage yang tersedia di Vercel Marketplace bila kelak diperlukan; saat ini batas 4 MB.
Coverage / ASVS belum terverifikasi	Tinggi	Target mutu proposal belum dapat diklaim tercapai.	Jalankan CI penuh, lampirkan coverage, bukti ASVS dan review pembimbing.

9.2 Rencana Pekerjaan Berikutnya

Tahap	Aktivitas	Keluaran / kriteria selesai
1. Repository	Buat `zerocool979/scopeline`, push source, sertakan README dan dokumen teknis.	Repository aktif; branch utama dan commit awal tercatat.
2. Database	Provision PostgreSQL melalui Vercel Marketplace; koneksi khusus SCOPELINE.	Koneksi berhasil; skema Alembic mencapai head; backup aktif.
3. Secrets	Pasang DATABASE_URL, SECRET_KEY, ADMIN_PASSWORD secara sensitif di Vercel.	Startup tidak menghasilkan error konfigurasi; tidak ada secret di source.
4. Deployment	Hubungkan GitHub project; deploy branch production.	Deployment READY dan fungsi berjalan.
5. Health / smoke test	GET /api/health, login, MFA, CRUD user/engagement, approval RoE, finding, evidence, retest, DOCX.	Hasil test berisi HTTP status, timestamp dan screenshot/log tanpa data rahasia.
6. Security review	Uji RBAC, object ownership, upload, XSS, lockout, CSP, token revocation.	Checklist ASVS evidence; tidak ada critical/high yang terbuka.
7. Performance / acceptance	Ukur laporan <10 menit, test coverage ≥70%, uji cold-start dan koneksi DB.	Laporan penerimaan yang disetujui PM/pembimbing.
8. Domain / akses	Tentukan nama domain alternatif yang benar-benar dapat dipasang; tinjau SSO protection.	Domain verified, TLS dan akses publik/internal sesuai kebijakan.

9.3 Rekomendasi Tahap Berikut

Prioritas pertama bukan menambah fitur, melainkan menyelesaikan dasar operasi: repository source-of-truth, database PostgreSQL persisten, rahasia deployment, dan deployment pertama yang dapat diverifikasi. Setelah itu jalankan smoke test serta rangkaian uji regresi. Pengukuran target proposal harus menghasilkan bukti yang dapat diaudit. Pemakaian data klien nyata tidak boleh dimulai sebelum kontrol backup, retensi, hak akses, log dan keamanan database dikaji.

BAB X KESIMPULAN

Analisis terhadap proposal, draft teknis terdahulu, dan source SCOPELINE 1.1.0 menunjukkan bahwa sistem telah berkembang dari rancangan awal menjadi aplikasi manajemen engagement yang memiliki modul autentikasi, RBAC, engagement dan persetujuan RoE, pencatatan temuan, kalkulasi CVSS, bukti, review empat mata, retest berulang, template laporan, catatan Markdown, dashboard, audit dan impor CSV. Penambahan v1.1 memperkuat pengendalian mutu laporan dan pemisahan tugas.

Rancangan produksi yang dituju menggunakan FastAPI pada Vercel dengan database PostgreSQL persisten melalui integrasi Vercel Marketplace. Penggunaan SQLite atau filesystem sementara sebagai data production tidak sesuai untuk deployment serverless. Kompromi implementasi di Vercel meliputi PDF export yang dinonaktifkan, upload 4 MB, dan kebutuhan secret/database yang harus dipasang. Dengan demikian, kode dan konfigurasi dasar telah disiapkan, tetapi project belum live dan belum memenuhi bukti penerimaan deployment.

Kesimpulan kelayakan teknis: source v1.1 menyediakan fondasi fitur inti untuk demonstrasi sistem manajemen dan pelaporan. Pernyataan bahwa target kinerja, coverage minimal 70%, ketiadaan temuan keamanan kritis/tinggi, atau ketersediaan produksi telah tercapai harus menunggu hasil CI, uji keamanan, provision database, deployment dan smoke test yang berhasil. Pendekatan ini menjaga keterlacakan antara proposal manajemen, keputusan analis program dan hasil implementasi secara jujur.

DAFTAR PUSTAKA

[1] Bilal dan Denvi. (2026, 7 Oktober). Usulan Judul & Key Objective Proyek: SCOPELINE - Platform Manajemen Engagement dan Pelaporan Penetration Testing Berbasis Web. Proposal proyek, versi 0.1 pada salinan yang tersedia.

[2] Denvi Sekartazi Iskandar. (2026/2027). Analisis dan Perancangan Sistem SCOPELINE: Platform Manajemen Engagement dan Pelaporan Penetration Testing Berbasis Web. Draft Program Analysis, STMIK Tazkia.

[3] SCOPELINE. (2026). Source code v1.1.0 - README.md, CHANGELOG.md, backend/app, backend/app/migrations, backend/tests, e2e dan docs/ (baseline repository package).

[4] Vercel. (2025-2026). FastAPI on Vercel; Using the Python Runtime with Vercel Functions; Storage on Vercel Marketplace; Postgres on Vercel; Vercel Functions Limits. Diakses 10 November 2026. https://vercel.com/docs/frameworks/backend/fastapi ; https://vercel.com/docs/functions/runtimes/python ; https://vercel.com/docs/marketplace-storage ; https://vercel.com/docs/postgres ; https://vercel.com/docs/functions/limitations

[5] FIRST. (2019). Common Vulnerability Scoring System v3.1: Specification Document. https://www.first.org/cvss/v3.1/specification-document

[6] OWASP Foundation. (2021). Application Security Verification Standard 4.0.3. https://owasp.org/www-project-application-security-verification-standard/

[7] Elmasri, R., & Navathe, S. B. (2016). Fundamentals of Database Systems (7th ed.). Pearson.

[8] Fielding, R. T. (2000). Architectural Styles and the Design of Network-based Software Architectures. University of California, Irvine.

[9] Pressman, R. S., & Maxim, B. R. (2020). Software Engineering: A Practitioner's Approach (9th ed.). McGraw-Hill.

[10] Sandhu, R. S., Coyne, E. J., Feinstein, H. L., & Youman, C. E. (1996). Role-based access control models. Computer, 29(2), 38-47.

[11] Sommerville, I. (2016). Software Engineering (10th ed.). Pearson.

LAMPIRAN A - CHECKLIST PENERIMAAN DEPLOYMENT

☐ Repository `zerocool979/scopeline` dibuat dan branch utama berisi source v1.1.0.

☐ Vercel project terhubung ke repository/production branch.

☐ PostgreSQL khusus SCOPELINE diprovisikan melalui Vercel Marketplace dan DATABASE_URL terpasang.

☐ SECRET_KEY dan ADMIN_PASSWORD dipasang sebagai environment variables sensitif.

☐ FastAPI deployment READY; GET /api/health menghasilkan status ok.

☐ Bootstrap admin, ganti password dan aktivasi MFA diuji.

☐ RoE gate, assignment dan seluruh status workflow diuji.

☐ CVSS, evidence BLOB, DOCX, template, notes, review dan retest diuji.

☐ PDF disabled di Vercel dikomunikasikan kepada pengguna.

☐ Upload maksimum 4 MB; upload oversize ditolak.

☐ CI coverage ≥70%, Bandit, Ruff, pip-audit, PostgreSQL integration dan E2E lulus.

☐ ASVS checklist ditinjau pembimbing; tidak ada critical/high yang terbuka.

☐ Domain resmi verified; SSO protection/access policy ditinjau.

☐ Backup, retensi, restore test dan prosedur incident response ditetapkan.